Control ID	Control Name	Theme	Applicable	Control Owner	Justification	Implementation Status	Linked Risk(s)	ITGC Evidence
5.1	Policies for information security	Organizational	Yes	Top Management	Required by the ISMS (Clause 5.2); sets direction for all other controls.	Not Assessed	None	None
5.2	Information security roles and responsibilities	Organizational	Yes	Top Management	Required by the ISMS (Clause 5.3); owners are assigned in the Risk Register.	Not Assessed	None	None
5.3	Segregation of duties	Organizational	Yes	IT Manager	The privileged access review operates (UAM-04), but it is performed within the same IT reporting line as provisioning, which limits independence.	Partially Implemented	R-004	UAM-T004 (Q1 interim); 07-Audit-Report (Observation 1)
5.4	Management responsibilities	Organizational	Yes	Top Management	Management must require personnel to follow the security policy.	Not Assessed	None	None
5.5	Contact with authorities	Organizational	Yes	Legal	Regulatory and incident reporting obligations apply to a SaaS provider.	Not Assessed	None	None
5.6	Contact with special interest groups	Organizational	Yes	IT Manager	Supports threat awareness for an internet-facing SaaS platform.	Not Assessed	None	None
5.7	Threat intelligence	Organizational	Yes	IT Manager	Internet-facing platform on AWS is exposed to evolving threats.	Not Assessed	None	None
5.8	Information security in project management	Organizational	Yes	Engineering Manager	Engineering-driven development model.	Not Assessed	None	None
5.9	Inventory of information and other associated assets	Organizational	Yes	IT Manager	Asset identification supports risk assessment.	Not Assessed	None	None
5.10	Acceptable use of information and other associated assets	Organizational	Yes	IT Manager	Applies to all personnel using in-scope systems.	Not Assessed	None	None
5.11	Return of assets	Organizational	Yes	HR	Applies at termination; UAM-03 covers account removal only.	Not Assessed	None	None
5.12	Classification of information	Organizational	Yes	IT Manager	Customer data requires classification.	Not Assessed	None	None
5.13	Labelling of information	Organizational	Yes	IT Manager	Supports the classification scheme.	Not Assessed	None	None
5.14	Information transfer	Organizational	Yes	IT Manager	Customer data is exchanged with customers and suppliers.	Not Assessed	None	None
5.15	Access control	Organizational	Yes	IT Manager	Core control for production access.	Implemented	R-001; R-002; R-009	UAM-T001; UAM-T002 (Q1 interim)
5.16	Identity management	Organizational	Yes	IAM Administrator	Identity lifecycle is managed through Okta.	Implemented	R-002; R-003	UAM-T002; UAM-T003 (Q1 interim)
5.17	Authentication information	Organizational	Yes	IAM Administrator	Authentication information is required to support secure user authentication.	Not Assessed	None	None
5.18	Access rights	Organizational	Yes	Application Owners	Provisioning, review and removal of access.	Implemented	R-001; R-002; R-003; R-004	UAM-T001 to UAM-T004 (Q1 interim)
5.19	Information security in supplier relationships	Organizational	Yes	IT Manager	AWS and integrated SaaS applications are suppliers; vendor risk management is outside audit scope.	Not Assessed	R-012	None
5.20	Addressing information security within supplier agreements	Organizational	Yes	Legal	Supplier contracts should state security requirements; not examined.	Not Assessed	None	None
5.21	Managing information security in the ICT supply chain	Organizational	Yes	IT Manager	Dependence on AWS and Okta.	Not Assessed	None	None

5.22	Monitoring, review and change management of supplier services	Organizational	Yes	IT Manager	Connected third-party applications; not examined.	Not Assessed	R-012	None
5.23	Information security for use of cloud services	Organizational	Yes	Infrastructure Operations	Cloud-first environment on AWS.	Not Assessed	R-010; R-012	None
5.24	Information security incident management planning and preparation	Organizational	Yes	IT Manager	Incident management process exists; planning documentation was outside the ITGC audit scope.	Not Assessed	R-008	None
5.25	Assessment and decision on information security events	Organizational	Yes	IT Manager	Incidents are logged and assessed.	Implemented	R-008	OPS-T003 (Q1 interim)
5.26	Response to information security incidents	Organizational	Yes	IT Manager	Incidents are investigated and resolved.	Implemented	R-008	OPS-T003 (Q1 interim)
5.27	Learning from information security incidents	Organizational	Yes	IT Manager	Lessons-learned activity not examined.	Not Assessed	R-008	None
5.28	Collection of evidence	Organizational	Yes	IT Manager	Needed for incident investigation.	Not Assessed	None	None
5.29	Information security during disruption	Organizational	Yes	Infrastructure Operations	Availability commitments to enterprise customers.	Not Assessed	None	None
5.30	ICT readiness for business continuity	Organizational	Yes	Infrastructure Operations	Backup monitoring is tested (OPS-T001); continuity planning and restore testing were not examined.	Partially Implemented	R-006	OPS-T001 (Q1 interim)
5.31	Legal, statutory, regulatory and contractual requirements	Organizational	Yes	Legal	The Interested Parties Register identifies contractual and regulatory requirements.	Not Assessed	None	None
5.32	Intellectual property rights	Organizational	Yes	Legal	Software company using licensed software.	Not Assessed	None	None
5.33	Protection of records	Organizational	Yes	IT Manager	ISMS and audit records must be protected.	Not Assessed	None	None
5.34	Privacy and protection of personal identifiable information (PII)	Organizational	Yes	Legal	Customer data may include PII; regulators are interested parties.	Not Assessed	None	None
5.35	Independent review of information security	Organizational	Yes	Security/ Compliance function (role to be assigned)	Independent co-review of privileged access is approved as the treatment for R-004 (see 13-Management-Review).	Planned	R-004	07-Audit-Report (Recommendation 1)
5.36	Compliance with policies, rules and standards for information security	Organizational	Yes	Top Management	Internal audit and management review (Clauses 9.2 and 9.3).	Not Assessed	None	None
5.37	Documented operating procedures	Organizational	Yes	Infrastructure Operations	Operating procedures for backup and batch processing; not examined.	Not Assessed	R-007	None
6.1	Screening	People	Yes	HR	Personnel with access to production require background verification.	Not Assessed	None	None
6.2	Terms and conditions of employment	People	Yes	HR	Employment terms should state security responsibilities.	Not Assessed	None	None
6.3	Information security awareness, education and training	People	Yes	HR	Required for all personnel (Clause 7.3).	Not Assessed	None	None
6.4	Disciplinary process	People	Yes	HR	Needed to act on policy violations.	Not Assessed	None	None

6.5	Responsibilities after termination or change of employment	People	Yes	HR	UAM-03 covers account removal only; post-termination duties not examined.	Not Assessed	R-003	None
6.6	Confidentiality or non-disclosure agreements	People	Yes	Legal	Enterprise customer data and contracts.	Not Assessed	None	None
6.7	Remote working	People	Yes	IT Manager	Cloud-first environment; production access is not tied to office premises.	Not Assessed	None	None
6.8	Information security event reporting	People	Yes	IT Manager	Reporting channels not examined.	Not Assessed	R-008	None
7.1	Physical security perimeters	Physical	No	N/A	Data center physical security is AWS's responsibility under the shared responsibility model; offices are outside the ISMS scope. AWS assurance was not reviewed (vendor risk management is outside audit scope).	Not Applicable	None	None
7.2	Physical entry	Physical	No	N/A	Data center entry controls are AWS's responsibility; offices are outside the ISMS scope. AWS assurance was not reviewed.	Not Applicable	None	None
7.3	Securing offices, rooms and facilities	Physical	No	N/A	Production runs in AWS facilities; BlueSky offices are outside the ISMS scope. AWS assurance was not reviewed.	Not Applicable	None	None
7.4	Physical security monitoring	Physical	No	N/A	Monitoring of data center premises is AWS's responsibility; offices are outside the ISMS scope. AWS assurance was not reviewed.	Not Applicable	None	None
7.5	Protecting against physical and environmental threats	Physical	No	N/A	Protection of data center infrastructure is AWS's responsibility. AWS assurance was not reviewed.	Not Applicable	None	None
7.6	Working in secure areas	Physical	No	N/A	No BlueSky-operated secure areas exist within the production scope; data center areas are AWS's responsibility.	Not Applicable	None	None
7.7	Clear desk and clear screen	Physical	Yes	IT Manager	Applies to staff devices and workspaces used to access production systems.	Not Assessed	None	None
7.8	Equipment siting and protection	Physical	No	N/A	Production infrastructure is hosted on AWS; equipment siting is AWS's responsibility.	Not Applicable	None	None
7.9	Security of assets off-premises	Physical	Yes	IT Manager	Laptops used off-premises can access production systems.	Not Assessed	None	None
7.10	Storage media	Physical	Yes	IT Manager	Removable media on endpoints could hold production or customer data.	Not Assessed	None	None
7.11	Supporting utilities	Physical	No	N/A	Power and utilities for production are provided by AWS data centers. AWS assurance was not reviewed.	Not Applicable	None	None
7.12	Cabling security	Physical	No	N/A	Data center cabling is AWS's responsibility.	Not Applicable	None	None
7.13	Equipment maintenance	Physical	No	N/A	Maintenance of production hardware is AWS's responsibility.	Not Applicable	None	None
7.14	Secure disposal or re-use of equipment	Physical	Yes	IT Manager	Endpoint devices that accessed production data must be wiped before disposal or re-use.	Not Assessed	None	None
8.1	User end point devices	Technological	Yes	IT Manager	Endpoints are used to access production; endpoint security tooling is listed in the Company Profile but was not tested.	Not Assessed	None	None
8.2	Privileged access rights	Technological	Yes	IAM Administrator	Privileged access is reviewed quarterly (UAM-04), but the review lacks independence from IT.	Partially Implemented	R-004	UAM-T004 (Q1 interim); 07-Audit-Report (Observation 1)

8.3	Information access restriction	Technological	Yes	IT Manager	Restricts access to customer data in production; not tested.	Not Assessed	R-009	None
8.4	Access to source code	Technological	Yes	Engineering Manager	Source code and development tools must be access-controlled; not tested.	Not Assessed	R-011	None
8.5	Secure authentication	Technological	Yes	IAM Administrator	MFA enforcement was not tested within ITGC scope.	Not Assessed	R-009	None
8.6	Capacity management	Technological	Yes	Infrastructure Operations	Backup failure INC-3001 was caused by storage nearing capacity; capacity management was not assessed.	Not Assessed	None	None
8.7	Protection against malware	Technological	Yes	IT Manager	Applies to endpoints and production systems; not tested.	Not Assessed	None	None
8.8	Management of technical vulnerabilities	Technological	Yes	Infrastructure Operations	Internet-facing platform on AWS; not tested.	Not Assessed	None	None
8.9	Configuration management	Technological	Yes	Infrastructure Operations	Cloud configuration monitoring is approved for implementation to treat R-010.	Planned	R-010	None
8.10	Information deletion	Technological	Yes	Engineering Manager	Customer data must be deleted when no longer required; not tested.	Not Assessed	None	None
8.11	Data masking	Technological	Yes	Engineering Manager	Customer data may appear in non-production use; not tested.	Not Assessed	None	None
8.12	Data leakage prevention	Technological	Yes	IT Manager	Customer data is held and transmitted by the platform; not tested.	Not Assessed	None	None
8.13	Information backup	Technological	Yes	Infrastructure Operations	Backups are monitored and failures investigated (OPS-T001); restore testing was not covered.	Partially Implemented	R-006	OPS-T001 (Q1 interim)
8.14	Redundancy of information processing facilities	Technological	Yes	Infrastructure Operations	Availability commitments to enterprise customers; not tested.	Not Assessed	None	None
8.15	Logging	Technological	Yes	Infrastructure Operations	Job execution records support monitoring (OPS-T002); security event logging was not examined.	Partially Implemented	R-007	OPS-T002 (Q1 interim)
8.16	Monitoring activities	Technological	Yes	Infrastructure Operations	Batch job monitoring was tested (OPS-T002); security monitoring of networks and applications was not examined, so no evidence supports this control for R-010.	Partially Implemented	R-007; R-010	OPS-T002 (Q1 interim)
8.17	Clock synchronization	Technological	Yes	Infrastructure Operations	Required for reliable log correlation and audit trails; not tested.	Not Assessed	None	None
8.18	Use of privileged utility programs	Technological	Yes	Infrastructure Operations	Utilities that can override controls exist in the production environment; not tested.	Not Assessed	None	None
8.19	Installation of software on operational systems	Technological	Yes	Infrastructure Operations	Applies to production systems; not tested.	Not Assessed	None	None
8.20	Networks security	Technological	Yes	Infrastructure Operations	Applies to the AWS production network; not tested.	Not Assessed	None	None
8.21	Security of network services	Technological	Yes	Infrastructure Operations	Applies to network services used by production; not tested.	Not Assessed	None	None
8.22	Segregation of networks	Technological	Yes	Infrastructure Operations	Applies to production network design; not tested.	Not Assessed	None	None
8.23	Web filtering	Technological	No	N/A	Web filtering applies to staff internet access on corporate IT, which is outside the ISMS scope (production environment).	Not Applicable	None	None

8.24	Use of cryptography	Technological	Yes	Infrastructure Operations	Customer data on AWS requires protection in transit and at rest. No encryption risk is currently registered; to be assessed in the next risk assessment cycle.	Not Assessed	None	None
8.25	Secure development life cycle	Technological	Yes	Engineering Manager	Secure SDLC controls are approved for development to treat R-011.	Planned	R-011	None
8.26	Application security requirements	Technological	Yes	Engineering Manager	Applies to the SaaS application; not tested.	Not Assessed	None	None
8.27	Secure system architecture and engineering principles	Technological	Yes	Engineering Manager	Applies to the cloud-native platform; not tested.	Not Assessed	None	None
8.28	Secure coding	Technological	Yes	Engineering Manager	Secure coding principles are approved for development to treat R-011.	Planned	R-011	None
8.29	Security testing in development and acceptance	Technological	Yes	Engineering Manager	Change testing evidence exists (CHG-T001), but security testing was not examined.	Not Assessed	R-005; R-011	None
8.30	Outsourced development	Technological	No	N/A	No outsourced development is described in the portfolio; to be reconsidered if development is outsourced.	Not Applicable	None	None
8.31	Separation of development, test and production environments	Technological	Yes	Engineering Manager	Deployment evidence (E-014) covers production only; environment separation was not examined.	Not Assessed	R-005	None
8.32	Change management	Technological	Yes	Change Manager	Production changes are approved, tested and deployed under a defined process.	Implemented	R-005	CHG-T001 (Q1 interim)
8.33	Test information	Technological	Yes	Engineering Manager	Applies where test data is used; not tested.	Not Assessed	None	None
8.34	Protection of information systems during audit testing	Technological	Yes	IT Manager	Audit activities touching operational systems must be planned and agreed; not tested.	Not Assessed	None	None